

RADIANT NORMA

Pacote de Conformidade Enterprise

SOC 2 Type I Readiness · LGPD · BACEN Compliance · Segurança

Versão 1.0 — Julho 2026

Classificação CONFIDENCIAL

Empresa Radiant Tecnologia e Sistemas LTDA

Documentos SLA · Backup/DR · SOC 2 · LGPD · Pentest · Arquitetura

CONFIDENCIAL

Resumo Executivo

O **Radiant Norma** é uma plataforma B2B de inteligência regulatória que automatiza o ciclo de vida completo de documentos CADOC junto ao Banco Central do Brasil (BACEN). Este pacote de conformidade apresenta a postura de segurança, privacidade e continuidade de negócio da plataforma para clientes enterprise e auditores.



Resultado da Avaliação de Segurança (Sprint 78)

0 vulnerabilidades CRÍTICAS · 2 ALTAS · 4 MÉDIAS · 3 BAIXAS

Todas as vulnerabilidades ALTAS/MÉDIAS possuem plano de remediação documentado.

Cobertura de Conformidade

FRAMEWORK	STATUS	DOCUMENTO DE REFERÊNCIA
LGPD	✓ READY	LGPD_COMPLIANCE.md — DPA, Privacy Policy, DPO, DSAR
SOC 2 Type I	🟡 READINESS	SOC2_READINESS.md — Controls catalog, policies, gaps
SOC 2 Type II	○ PLANEJADO	Q2-Q3 2027 (após 6-12 meses de operação)
BACEN Compliance	✓ IMPLEMENTED	Hash-chain audit, STA idempotency, DLQ, L1-L4 validation
Internal Pentest	✓ COMPLETE	PENTEST_REPORT.md — Findings, hardening, remediation
External Pentest	🟡 Q3 2026	Engajamento com firma certificada em andamento

Diferenciais de Segurança

- ✓ JWT RS256 com rotação de chave (kid header)
- ✓ Postgres RLS FORCE mode — isolamento por tenant
- ✓ Hash-chain audit log (SHA-256) + dual-write
- ✓ HMAC-SHA256 para webhooks outbound
- ✓ Rate limiting Redis sliding window (atomic)

- ✓ Fail-closed em produção (RADIANT_ENV=production)
- ✓ Slowloris protection (ReadHeaderTimeout 10s)
- ✓ DLQ para submissions que falham no STA
- ✓ Idempotency key + XML hash deduplication
- ✓ CSRF protection (double-submit cookie)

Arquitetura de Segurança

Modelo de Autenticação e Autorização

CAMADA	MECANISMO	IMPLEMENTAÇÃO
API Authentication	JWT RS256	Rotação via kid header; keyring; RADIANT_JWT_KID
Multi-tenancy	Postgres RLS (FORCE)	SET LOCAL app.if_id por transação; isolation level
Admin Operations	Token separado	RADIANT_NORMA_ADMIN_TOKEN; fail-closed em prod
Dev Mode	X-IF-ID fallback	Warning em logs; bloqueado em RADIANT_ENV=production

Proteções Aplicativas

PROTEÇÃO	DESCRIÇÃO	STATUS
Rate Limiting	Per-tenant; per-endpoint; Redis sliding window (atomic Lua)	✓
Slowloris	ReadHeaderTimeout=10s; ReadTimeout=30s	✓
CSRF	Double-submit cookie pattern; X-CSRF-Token header	✓
Webhook Replay	HMAC-SHA256 signature; idempotency key	✓
SQL Injection	Parameterized queries (sqlx); sem string concat	✓
Error Leakage	loggerutil.SafeError — DSN nunca vaza	✓
DDoS via SSE	Max 10 subscribers/tenant; cap por IF	✓

Stack Tecnológico de Segurança

- ✓ Go 1.25+ com chi router (performance + tipagem)
- ✓ PostgreSQL 16 com RLS nativo
- ✓ Redis (rate limiting, session cache)
- ✓ OTEL (traces) + Sentry (errors)
- ✓ Prometheus (métricas)

- ✓ AWS EC2/RDS/S3/CloudWatch
- ✓ Cloudflare (DDoS protection + WAF)
- ✓ TLS 1.3 enforced; HSTS
- ✓ Secrets via AWS Secrets Manager
- ✓ Backup criptografado (S3 SSE-S3)

SOC 2 Type I – Readiness

O SOC 2 Type I avalia a adequação dos controles de segurança em um ponto no tempo. O Radiant Norma possui readiness package completo para auditoria externa, agendada para Q4 2026.

Trust Service Criteria – Cobertura

CRITÉRIO	STATUS	CONTROLES PRINCIPAIS
Security (CC)	✓ Implementado	JWT RS256, RLS, MFA, fail-closed, CSRF, HMAC webhooks
Availability (A)	✓ Implementado	Graceful shutdown, DLQ, retry backoff, status page, monitoring
Confidentiality (C)	✓ Implementado	TLS 1.3, AES-256, RLS, secrets manager, error sanitization
Processing Integrity (PI)	✓ Implementado	Idempotency, atomic transactions, hash-chain audit, dual-write
Privacy (P)	✓ Implementado	DPA, consent management, DPO appointed, DSAR procedures

Maturidade de Controles

ÁREA	NÍVEL (1-5)	DESCRIÇÃO
Access Control	4 – Gerenciado	MFA; RBAC; secrets manager; baseline monitorado
Audit Logging	4 – Gerenciado	Hash chain; dual-write; tamper-evident; OTel
Encryption	4 – Gerenciado	TLS 1.3; AES-256; key rotation implementada
Change Management	3 – Definido	CI/CD; peer review; immutable deploys
Incident Response	3 – Definido	Playbooks documentados; SEV-1/2/3/4 definidos
Backup & Recovery	3 – Definido	WAL + full + snapshot; PITR; DR drill planejado
Security Monitoring	4 – Gerenciado	OTel + Sentry + Prometheus + PagerDuty

Gaps e Plano de Remediação SOC 2

Gaps em aberto

- SOC 2 Type II audit externo (Q4 2026)
- Pentest externo (Q3 2026)
- SIEM implementation (Q4 2026)
- DR drill formal (Q3 2026)

PRÓXIMOS PASSOS



Q3 2026

Pentest Externo

Firma especializada certificada



Q4 2026

SOC 2 Type I Audit

Auditor externo проводит assessment



Q2-Q3 2027

Conformidade LGPD

A Radiant opera como **Operadora de dados** (Art. 5º VI LGPD) para seus clientes (Instituições Financeiras). Possuímos DPO designado, DPA documentado, e procedimentos para direitos dos titulares.

DPO DESIGNADO E ATIVO	72h NOTIFICAÇÃO DE INCIDENTES (ANPD)	7 anos RETENÇÃO DADOS REGULATÓRIOS	15 dias RESPOSTA DSAR
---------------------------------	--	--	---------------------------------

Dados Pessoais Tratados

CATEGORIA	DADOS	BASE LEGAL	RETENÇÃO
Cadastrais IF	CNPJ, nome, segmento	Art. 7º IX	Contrato + 5 anos
Contato Técnico	Nome, email, telefone	Art. 7º II/IX	Contrato + 5 anos
CADOC Submissions	XML payloads regulatórios	Art. 7º II (obrigação legal)	7 anos
Audit Logs	Hash chain; actor; action	Art. 7º IX	7 anos

Direitos dos Titulares (Art. 18 LGPD)

✓ Confirmação e acesso a dados	✓ Informação sobre compartilhamento
✓ Correção de dados incompletos	✓ Revogação de consentimento
✓ Anonimização ou eliminação	✓ Resposta em até 15 dias úteis
✓ Portabilidade (formato interoperável)	✓ Canal: privacidade@radiant.digital

Incidentes de Segurança (Art. 48)

Notificação ao Controlador e à ANPD em até **72 horas** após conhecimento de qualquer incidente que represente risco aos direitos dos titulares. Processo documentado em SOC2_READINESS.md Seção 6.

Transferência Internacional

DESTINO	SERVIÇO	SALVAGUARDA
Estados Unidos	AWS (EC2, RDS, S3)	AWS Data Processing Agreement + SCCs
Europa	OpenAI (GPT-4, se LLM configurado)	Standard Contractual Clauses

SLA e Continuidade de Negócios

Níveis de Serviço por Tier

MÉTRICA	STARTER	PROFESSIONAL	ENTERPRISE
Uptime Garantido	99,0%	99,5%	99,9%
Downtime Máximo/Mês	7h 18min	3h 39min	43min 49seg
MTTR (tempo recuperação)	8h úteis	4h úteis	1h útil
RPO (Recovery Point)	24h	1h	≤ 1h (WAL)
RTO (Recovery Time)	24h	4h	≤ 4h
Backup	Diário	A cada 6h	Contínuo (WAL)
Suporte	Email	Email + Chat	Email + Chat + Telefone 24/7
Canais de Suporte	Email	Email + Chat	Email + Chat + Telefone

Desastre e Recovery

ESTRATÉGIA DE BACKUP

- ✓ WAL contínuo (PITR, RPO = 0 teórico)
- ✓ Full backup diário (01:00 BRT)
- ✓ Snapshot mensal (cold storage S3)
- ✓ Retenção: 30 dias (WAL + full)
- ✓ S3 Object Lock (immutable)

DR REGION

- ✓ Região secundária AWS
- ✓ Failover via Route53 DNS
- ✓ DR drill trimestral
- ✓ Restore validation em staging
- ✓ RTO ≤ 4h / RPO ≤ 1h

Exclusões de SLA

Não contam para downtime: manutenção programada (72h aviso), falhas de infraestrutura do cliente, indisponibilidade do BACEN/STA, força maior, ou uso indevido acima dos limites contratados.

Conformidade BACEN

O Radiant Norma processa CADOCs (Comunicações, Documentos e Orientações) para o Banco Central do Brasil. A plataforma implementa validação em 4 camadas e garantia de entrega com idempotência e DLQ.

Cobertura de CADOCs

CADOC	SIGLA	PERIODICIDADE	GERADOR	VALIDAÇÃO
3040	SCR — Risco de Crédito	Mensal	✓	✓ 275 regras
3050	Estatísticas Agregadas	Mensal/diária	✓	✓ 170 regras
2060	DRM — Risco de Mercado	Mensal	✓	✓ 22 regras
2061	DLO — Limites Operacionais	Mensal	✓	✓ 24+ regras
2062	DLI — Limites Individuais	Mensal	✓	✓ 18 regras
2070	DDR — Requerimento Capital	Diário	✓	✓ 11 regras + cross-doc
2160	DRL — Liquidez (LCR)	Diário	✓	✓ 11 regras
2170	DLP — Liquidez LP (NSFR)	Mensal	✓	✓ 10 regras
3044	Eventos de Crédito	Por evento	✓	✓ 17 regras
2030	DRSAC — Risco ESG	Semestral	✓	🕒 0 (regras não-públicas)

Camadas de Validação (L1→L4)

L1 XSD SCHEMA	L2 SEMÂNTICO (GO)	L3 CROSS-DOCUMENT	L4 HISTÓRICO
------------------	----------------------	----------------------	-----------------

Garantia de Entrega ao STA

- ✓ **Idempotency Key** — 1º nível de dedup (cliente envia)
- ✓ **XML Hash Dedup** — 2º nível (conteúdo idêntico)
- ✓ **Dead Letter Queue** — submissions com falha persistente após 5 retries
- ✓ **Retry Backoff** — [1s, 5s, 15s, 30s, 60s] exponencial
- ✓ **Admin DLQ Visibility** — /v1/admin/dlq (apenas role admin)

Hash chain SHA-256 em cada entrada de audit_log. Dual-write atômico: audit_log (hash chain) + audit_events (legível) na mesma transação. Verify endpoint para validação de integridade.

Avaliação de Vulnerabilidades e Hardening

Avaliação interna de segurança completada no Sprint 78. Pentest externo independente agendado para Q3 2026.



Findings de Segurança

ID	SEVERIDADE	DESCRIÇÃO	STATUS
HIGH-01	ALTA	Mass Assignment em API de Toggle de Regras	Remediação Q3 2026
HIGH-02	ALTA	Rate Limit via X-Forwarded-For bypass (config-dependente)	Mitigado em prod
MED-01	MÉDIA	CSRF em GET requests (SameSite cookie a verificar)	A verificar
MED-02	MÉDIA	JWT Audience claim não verificado	Remediação Q3 2026
LOW-01	BAIXA	IDs numéricos sequenciais em URLs (mitigado por RLS)	Mitigado
LOW-02	BAIXA	Security headers missing (X-Frame-Options, etc.)	A corrigir

Hardening Implementado (Sprint 78)

AUTENTICAÇÃO

- ✓ JWT RS256 com rotação (kid)
- ✓ Fail-closed em produção
- ✓ Postgres RLS FORCE mode
- ✓ Admin token fail-closed

PROTEÇÃO

- ✓ Slowloris: ReadHeaderTimeout 10s
- ✓ Rate limiter Redis sliding window
- ✓ CSRF double-submit cookie
- ✓ HMAC-SHA256 webhooks
- ✓ Idempotency + DLQ

Próximos Passos e Contato

Roadmap de Conformidade

- JULHO 2026**
Pacote de Conformidade Enterprise
Este documento: SLA, LGPD, SOC 2 Readiness, Pentest, Arquitetura
- Q3 2026**
Pentest Externo Independente
Firma de segurança certificada. Escopo: API, STA, webhooks, autenticação, multi-tenancy
- Q3 2026**
Remediação de Vulnerabilidades
HIGH-01 (mass assignment), MED-02 (JWT audience), LOW-02 (security headers)
- Q3 2026**
DR Drill Completo
Simulação de failover de região; validação de RTO/RPO
- Q4 2026**
SOC 2 Type I — Auditoria Externa
Auditor externo проводит assessment point-in-time. Objetivo: Type I report
- Q2-Q3 2027**
SOC 2 Type II
6-12 meses de operação com coleta de evidências; auditoria de efetividade

Documentos Completos Disponíveis

DOCUMENTO	DESCRIÇÃO
SLA.md	Service Level Agreement completo com tiers, tempos de resposta e créditos
BACKUP_DR_POLICY.md	Política de backup, PITR, DR procedures e runbooks
SOC2_READINESS.md	Readiness package SOC 2: controls catalog, policies, gap analysis
LGPD_COMPLIANCE.md	DPA, Privacy Policy, DPO docs, DSAR procedures, data inventory
PENTEST_REPORT.md	Relatório de pentest interno: findings, hardening, remediation plan
ARCHITECTURE_REVIEW.md	Revisão arquitetural completa: stack, segurança, integrações, ADRs
AUDIT.md	Arquitetura do sistema de auditoria: fases 1-13, hash chain, DLQ

Contatos

Suporte Comercial

comercial@radiant.digital

Suporte Técnico

Segurança

security@radiant.digital

DPO / Privacidade

Radiant Norma — Inteligência Regulatória para IFs Brasileiras

CNPJ: XX.XXX.XXX/XXXX-XX · radiant.digital